

1 Introduction

Learning Outcomes

- Learn about definitions and terms related to computer security.
了解语言计算系统安全相关的定义与术语
- Understand **confidentiality**, **integrity**, and **availability**.
了解理解保密性、完整性和可用性。

Computer System Concept 计算机系统概念

The protection afforded to an automated information system in order to attain the applicable objectives of preserving the **integrity, availability, and confidentiality** of **information system resources** (includes hardware, software, firmware, information/data, and telecommunications).

为自动化信息系统提供的保护，旨在实现维护信息系统资源（包括硬件、软件、固件、信息/数据和电信）**完整性、可用性和保密性**的适用目标。

CIA

There are 3 key objectives: **CIA**

- **Confidentiality** 保密性
- **Integrity** 完整性
- **Availability** 可用性

Confidentiality 保密性

Preserving authorized restrictions on information **access** and **disclosure**, including means for protecting personal privacy and proprietary information.

维护信息访问与**披露**的授权限制，包括保护个人隐私和专有信息的措施。

Integrity 完整性

Guarding against improper information **modification** or **destruction**, including ensuring information **nonrepudiation** and **authenticity**.

防范不当信息**修改或破坏**，包括确保信息的**不可否认性与真实性**。

Availability 可用性

Ensuring timely and reliable **access** to and **use** of information.

确保信息能够及时可靠地**获取和使用**。

Exercise

Which CIA is obviously violated in the following cases?

以下的案例中都分别违反了什么CIA原则

- The learning mall system is out of service.
可用性受损 Availability: Learning Mall 系统停机无法提供服务。

- Attacker compromised the university's server and leaked exam papers before the exams.

机密性受损 Confidentiality: 攻击者入侵服务器并在考试前泄露了试卷

- Attacker compromised the university's server and replaced exam papers of 25-26-S1 with previous years'.

完整性受损 Integrity: 攻击者篡改服务器数据，将本学期试卷替换为往年试卷。

- Attacker compromised the university's server and deleted exam papers.

综合破坏 Comprehensive: 攻击者删除试卷（直接导致可用性丧失，同时也破坏了数据的完整性）

Other Objectives

- **Authenticity 权威性**

- Verifying users are who they say they are. (users' authenticity)

- **Messages' authenticity: integrity**

验证用户的身份确实如其所言；对于消息而言，真实性与完整性紧密相关。

- **Accountability 责任制**

- Ensuring actions of an entity to be traced uniquely to that entity.

- Supports nonrepudiation, deterrence, intrusion detection and prevention, etc.

确保实体的行为可以被唯一地追溯。这支持了不可否认性、震慑犯罪以及入侵检测与预防。

Back to the Definition

Computer security deals with computer-related **assets** that are subject to a variety of **threats** and for which various **measures** are taken to protect those assets.

计算机安全涉及与计算机相关的资产，这些资产面临多种威胁，并需采取多种措施加以保护。在进行计算机安全研究时，必须要考虑的三个基本问题：

- What **assets** do we need to protect?

资产 (Assets): 我们需要保护哪些计算机相关的资产？

- How are those assets **threatened**?

威胁 (Threats): 这些资产面临哪些潜在的危险？

- What can we do to **counter** those threats?

对策 (Measures/Counters): 我们可以采取哪些措施来抵御这些威胁？

The assets and threats 资产与威胁

What assets do we need to protect?

我需要去保护那些资产？

How are assets threatened?

资产是如何被威胁的？

Computer-related assets 与计算机相关的资产

- System Resource (Asset)系统资源

- **Hardware:** Including computer systems and other data processing, data storage, and data communications devices

硬件 (Hardware): 包括计算机系统、数据处理、存储以及通信设备。

- **Software:** Including the operating system, system utilities, and applications.

软件 (Software): 包括操作系统、系统工具程序以及各类应用程序。

- **Data:** Including files and databases, as well as security-related data, such as password files.

数据 (Data): 包括文件、数据库以及安全相关数据（如密码文件）。

- **Communication facilities and networks:** Local and wide area network communication links, bridges, routers, and so on.

通信设施与网络 (Communication facilities and networks): 包括局域网/广域网通信链路、网桥、路由器等。

Threats to assets - Hardware 硬件威胁

- Majority Threat: **availability**

主要威胁：可用性

- Confidentiality, integrity

- Example:

- Equipment is stolen or disabled, thus denying service.

设备被盗或被禁用，导致服务中断。

- A laptop/smart phone/table storing unencrypted privacy data is stolen.

此外，存有未加密数据的移动设备（如笔记本、手机）被盗也会威胁机密性和完整性。

Threats to assets - Software

- Majority threat: availability

主要威胁：可用性

- Confidentiality, integrity

- Example:

- Programs are deleted, denying access to user

程序被删除导致用户无法访问

- A working program is modified by computer viruses, either to cause it to fail during execution or to cause it to do some unintended task.

或者程序被病毒篡改，导致运行失败或执行非预期任务（威胁完整性）

Threats to assets - Data

- A much more widespread problem is data security

数据安全是一个更广泛的问题，涉及 **CIA** 的所有方面。

- Availability, confidentiality, integrity

可用性、机密性、完整性

- Example:

- Files are deleted, denying access to users.

文件被删除（破坏可用性）

- An unauthorized read of data is performed.

未经授权的读取（破坏机密性）

- Existing files are modified, or new files are fabricated.

修改现有文件或伪造新文件（破坏完整性）

Threats to assets - Communication channels and Networks

- Network Security 网络安全
- Network security attacks
 - **Passive attacks:** are in the nature of eavesdropping on, or monitoring of, transmissions
 - 被动攻击：其本质在于对传输过程进行窃听或监控。
 - **Active attacks:** involve some modification of the data stream or the creation of a false stream
 - 主动攻击：涉及对数据流的篡改或伪造数据流。

Active Attack

- Replay
 - passive capture of a data unit
 - subsequent retransmission to produce an unauthorized effect
 - 重放 (Replay):** 被动截获数据单元，随后将其重新发送以产生授权外的效果。
- Masquerade
 - one entity pretends to be a different entity
 - 伪装 (Masquerade):** 一个实体假冒成另一个实体
- Modification of messages
 - some portion of a legitimate message is altered
 - messages are delayed or blocked
 - 消息修改 (Modification of messages):** 合法消息的部分内容被篡改、延迟或阻断。
- Denial of service
 - 拒绝服务 (DoS):** 阻碍网络服务的正常使用。

Exercise:

Which of CIA is/are obviously/directly violated under each attack?

针对上面的内容在每次攻击下，哪些CIA（机密性、完整性、可用性）属性明显/直接受到侵害？

Passive Attack

这类攻击本质上是偷听或监控传输内容。

- Leak of message contents
泄露消息内容
- Traffic analysis
网络流量分析
- Passive attacks are very difficult to detect because they do not involve any alteration of the data.
非常难以检测，因为它们不涉及任何数据的改动

Vulnerability 漏洞

- Vulnerability 漏洞
 - A flaw or weakness in a system's **design, implementation, or operation** and **management** that could be exploited to violate the system's security policy.
 - 漏洞是指系统在**设计、实现、操作或管理**上的缺陷或弱点，这些弱点可能被利用来违反系统的安全策略。

- Examples:
 - Missing security camera and security guard at the entrance of EE building
物理层面：EE大楼入口缺少监控摄像头和保安。
 - A weakness in a firewall that can lead to malicious hackers getting into a computer network
网络层面：防火墙存在弱点，可能导致黑客进入计算机网络。

- Exploit 利用
 - An actual incident of taking advantage of vulnerability.
指利用漏洞的实际事件
 - The term also refers to the code or methodology used to take advantage of vulnerability.
也可以指用于利用漏洞的代码或方法论。

Vulnerability vs Threat 漏洞与威胁的区别

- Threat 威胁
 - A **potential** for violation of security, which exists when there is a circumstance, capability, action, or event, that could breach security and cause harm.
是指一种潜在的安全违规可能性。当存在能够破坏安全并造成损害的情况、能力、行动或事件时，威胁就存在了。
- Vulnerability vs. threat
 - Vulnerabilities are not introduced to a system; rather they are there from the beginning.
漏洞是系统自带的，通常从系统开始运行或设计时就存在了
 - Threats are introduced to a system like a virus download or a social engineering attack.
威胁是外部引入的，例如病毒下载或社交工程攻击。
 - That is, a threat is a possible danger that might exploit a vulnerability.
逻辑关系：威胁是可能利用漏洞的潜在危险

Attack 攻击

Type of Attack: 对资源的影响

- **Active attack**: An attempt to alter system resources or affect their operation.
主动攻击 (Active attack): 试图改变系统资源或影响其运行。
- **Passive attack**: An attempt to learn or make use of information from the system that does not affect system resources.
被动攻击 (Passive attack): 试图学习或利用系统中的信息，但不会影响系统资源。

Are the following attacks active or passive?

- A denial of service (DoS) attack attempts to tie up a website's resource so that users who need to access the site cannot do so. **Active Attack**
拒绝服务 (DoS) 攻击（试图占用网站资源使他人无法访问）属于主动攻击。
- A timing side-channel attack attempts to leak a secret key by analyzing the time taken to execute cryptographical algorithms. **Passive Attack**
计时侧信道攻击 (Timing side-channel attack)（通过分析执行算法的时间来泄露密钥）属于被动攻击。

Types of Attacks: 攻击者的来源

- **Inside attack**: Initiated by an entity inside the security perimeter (an "insider"). The insider is authorized to access system resources but uses them in a way not approved by those who granted the authorization.

内部攻击 (Inside attack): 由安全边界内的实体（内部人员）发起。该人员拥有访问授权，但以非授权方式使用资源。

- **Outside attack:** Initiated from outside the perimeter, by an unauthorized or illegitimate user of the system (an “outsider”).

外部攻击 (Outside attack): 由系统边界外的非授权/非法用户发起。

Four kinds of threat consequences

- **Unauthorized disclosure**

未授权泄露

- **Deception**

欺骗

- **Disruption**

中断

- **Usurpation**

篡夺

Threat consequences (Unauthorized disclosure) and attacks 未授权泄露

- A circumstance or event whereby an entity gains access to data for which the entity is not authorized.
指非授权实体获得了对数据的访问权限，直接破坏了 **机密性 (Confidentiality)**
- Attack can result in unauthorized disclosure
 - **Exposure:** Sensitive data is directly released to an unauthorized entity.
暴露 (Exposure): 敏感数据被直接发布给非授权实体。
 - **Interception:** An unauthorized entity directly accesses sensitive data traveling between authorized sources and destinations.
拦截 (Interception): 非授权实体直接获取了在传输过程中的敏感数据。
 - **Inference:** An unauthorized entity indirectly accesses sensitive data by reasoning from characteristics or by-products of communications.
推断 (Inference): 通过分析通信特征或副产品，间接推断出敏感数据。
 - **Intrusion:** An unauthorized entity gains access to sensitive data by circumventing a system’s security protections.
入侵 (Intrusion): 通过绕过系统安全防护来获取数据。

Threat consequences (Deception) and attacks 欺骗

- A circumstance or event that may result in an authorized entity receiving false data and believing it to be true.
导致授权实体接收到虚假数据并信以为真，直接破坏了 **完整性 (Integrity)**
- Attacks can result in these consequences
 - **Masquerade:** An unauthorized entity gains access to a system or performs a malicious act by posing as an authorized entity.
伪装 (Masquerade): 非授权实体假冒成授权实体进入系统。
 - **Falsification:** False data deceive an authorized entity.
篡改/伪造 (Falsification): 使用虚假数据欺骗授权实体。
 - **Repudiation:** An entity deceives another by falsely denying responsibility for an act.
抵赖 (Repudiation): 一个实体虚假地否认其曾经执行过的行为。

Threat consequences (Disruption) and attacks 中断

- A circumstance or event that interrupts or prevents the correct operation of system services and functions.
干扰或阻止系统服务和功能的正常运行，直接破坏了 **可用性 (Availability)**
- Attacks can result in disruption
 - **Incapacitation**: Prevents or interrupts system operation by **disabling** a system component.
瘫痪 (Incapacitation): 通过禁用系统组件使系统停止运作。
 - **Corruption**: Undesirably alters system operation by adversely **modifying** system functions or data.
腐蚀 (Corruption): 通过恶意修改系统功能或数据，导致运行异常。
 - **Obstruction**: A threat action that interrupts delivery of system services by **hindering** system operation.
阻碍 (Obstruction): 干扰系统操作以中断服务交付。
- Examples:
恶意软件（如病毒）禁用系统或修改系统数据。
 - Malicious software (e.g., viruses) disable a system or some of its services.
 - Malicious software changes system data.
 - Threat consequences (Usurpation) and attacks

Threat consequences (Usurpation) and attacks 篡夺

- A circumstance or event that results in control of system services or functions by an unauthorized entity.
非授权实体获得了对系统服务或功能的控制权，直接破坏了 **完整性 (Integrity)** 或 **可用性 (Availability)**
- Attacks can result in this consequences
 - **Misappropriation**: An entity assumes unauthorized logical or physical control of a system resource.
非法侵占 (Misappropriation): 实体取得了对系统资源的逻辑或物理控制权
 - **Misuse**: Causes a system component to perform a function or service that is detrimental to system security.
滥用 (Misuse): 导致系统执行对安全有害的功能或服务

The countermeasures - Fundamental security design principles 反制手段-8种安全设计原则

What can we do to counter those threats?

为了对抗这些威胁，我们可以做什么

Design principles: Economy of mechanism 机制简洁性

- The design of security measures should be **economical** to develop, use and verify.
设计应尽量简单、小巧，以便于开发、验证和使用，**减少不必要的开销**。
- Should add little or no overhead.
应几乎不增加或完全不增加开销。
- Should do only what needs to be done.
仅做必须之事。
- Generally, try to keep it simple and small.
通常，应尽量保持简单和小型化。

Design principles: Fail-safe designs 故障安全默认

- Access decisions should be based on permission rather than exclusion
访问决策应基于“允许”而非“排除”
- Default to lack of access
默认情况下拒绝访问
- So if something goes wrong or is forgotten or isn't done, no security lost.
这样即使出错也不会泄露安全。

Design principles: Complete mediation 完全中介

对受保护对象的每一次访问都必须经过访问控制机制的检查，不能仅在第一次打开时检查。

- Apply security on every access to a protected object
每次访问受保护对象时均需施加安全措施。
 - Every access must be checked against the access control mechanism
每次访问都需通过访问控制机制进行验证。
- Typically, once a user has opened a file, no check is made to see if permissions change.
通常，用户打开文件后，系统不会检查权限是否发生变化。
- To fully implement complete mediation, every time a user reads a field or record in a file, or a data item in a database, the system must exercise access control.
为全面实施完全中介，每当用户读取文件中的字段或记录，或数据库中的数据项时，系统必须执行访问控制。

Design principles: Open design 开放设计

安全机制的设计应该是公开的，而不是依靠“隐蔽式安全”。即使攻击者知道设计细节，只要密钥安全，系统也应是安全的（Kerckhoffs原则）。

- The design of a security mechanism **should be open** rather than secret.
安全机制的设计应遵循开放而非保密的原则。
- Assume all potential attackers know everything about the design
假设所有潜在攻击者都完全了解设计细节。
 - And completely understand it
并完全理解它
- This doesn't necessarily mean publishing everything important about your security system
这并不意味着必须公布您安全系统的所有重要信息。
- **Kerckhoffs principle:** A cryptographic system should be secure even if everything about the system, except the key, is public knowledge.
克拉克霍夫原则：即使密码系统的所有细节（除密钥外）均已公开，该系统仍应保持安全性。

Design principles: Separation of privileges 权限分离

不同的权限应由不同的机制分开管理，以减少账户被盗后造成的潜在损害（例如：不要用同一个账户进行财务交易和删除日志）。

- Provide mechanisms that separate the privileges used for one purpose from those used for another.
提供将不同用途权限相分离的机制。
 - To allow flexibility in security systems

为使安全系统具备灵活性

- To mitigate the potential damage of a computer security attack

为减轻计算机安全攻击可能造成的损害

- Example

- Using a single **Root account** for both financial transactions and log deletion allows an attacker who compromises the password to steal money and erase the evidence trail.

使用单一**根账户**同时处理财务交易与日志删除，会使得攻击者在窃取密码后既能盗取资金又能抹除证据痕迹。

Design principles: Least privilege 最小权限

每个进程和用户仅拥有完成任务所需的最小权限集合。例如，腾讯会议必须明确请求摄像头权限。

- Every process and every user of the system should operate using the least set of privileges necessary to perform the task

系统的每个进程和每位用户都应以执行任务所需的最小权限集进行操作。

- Require another request to perform another type of access

需要另一个请求来执行另一种类型的访问。

- Example:

- Tencent Meeting must explicitly ask for permission to access your camera and microphone.

腾讯会议必须明确请求获取您的摄像头和麦克风访问权限。

Design principles: Least common mechanism 最少公共机制

尽量减少不同用户共享的功能，以防止由于系统耦合导致的侧信道攻击等漏洞。

- The design should minimize the functions shared by different users, providing mutual security

设计应最大限度减少不同用户间的功能共享，以提供相互安全保障。

- Coupling leads to possible security breaches

耦合可能导致安全漏洞

- Example:

- Side-channel attacks by exploiting OS shared memory mechanism

利用操作系统共享内存机制的侧信道攻击

Design principles: Psychological acceptability 心理可接受性

安全机制必须简单易用，不应经常干扰用户的合法操作，否则用户会倾向于绕过它。

- Mechanism must be simple to use

机制必须易于使用

- Simple enough that people will use it without thinking about it

简单到让人无需思考就能使用

- Must rarely or never prevent permissible accesses

必须极少或从不阻止允许的访问。

Computer security strategy 计算机安全策略

一个完整的安全策略涉及三个相互补充的方面：

- Specification/policy:

- What is the security scheme supposed to do?

规范/政策 (Specification/Policy): 定义安全方案“应该做什么”，描述安全系统的预期行为（例如：用户只能访问自己的文件）。

- Implementation/mechanisms:

- How does it do it?

实现/机制 (Implementation/Mechanisms): 定义“如何实现”，包括以下四个行动过程：

- Correctness/assurance:

- Does it really work?

正确性/保障 (Correctness/Assurance): 通过评估和测试来验证设计和实现是否符合要求，这通常体现为一种“置信度”。

Strategy: Security policies 安全策略

- Security policies describe how a secure system should behave.

安全策略描述了安全系统应如何运作。

- Policy says what should happen, not how you achieve that.

政策规定应**达成何种目标**，而非如何实现该目标。

- Example

- Informal security policies

非正式安全政策

- “Users should only be able to access **their own** files, in most cases.”

在大多数情况下，用户应仅能访问其自身的文件。

- “System executables should only be altered by system administrators.”

系统可执行文件仅应由系统管理员进行修改。

- In developing a security policy, a security manager needs to consider the following factors:

制定安全策略时，安全管理人员需综合考虑以下因素：

- The value of the assets being protected

受保护资产的价值

- The vulnerabilities of the system

该系统的漏洞

- Potential threats and the likelihood of attacks

潜在威胁与攻击发生的可能性

- Trade-offs

妥协

- Ease of use versus security

易用性与安全性

- Cost of security versus cost of failure and recovery

安全成本与故障恢复成本之比

Strategy: Security implementation 安全实施

- Security implementation involves four complementary courses of action:

- **Prevention 预防**

- encrypting the data, authenticate via password, etc.
加密、密码认证
- **Detection 检测**
 - intrusion detection, detection of DoS attack
入侵检测、DoS 攻击检测
- **Response 响应**
 - halt the attack and prevent further damage
停止攻击并防止进一步损
- **Recovery 恢复**
 - backup system
系统备份

Strategy: Assurance and evaluation 保证与评估

- Assurance deals with the questions:

保证处理以下问题：

- Does the security system design meet its requirements?
安全系统设计是否满足其要求？
- Does the security system implementation meet its specifications?
该安全系统的实施是否符合其规格要求？

- Assurance is expressed as a degree of confidence, not in terms of a formal proof that a design or implementation is correct.

确信度以置信程度表示，而非基于设计或实现正确性的形式化证明。

- Evaluation is the process of examining a computer product or system with respect to certain criteria. Evaluation involves testing and may also involve formal analytic or mathematical techniques.

评估是指依据特定标准对计算机产品或系统进行检验的过程。评估包括测试，也可能涉及形式化的分析或数学方法。

Tools for security

- Cryptographic tools
加密工具
- Access control
访问控制
- User authentication
用户认证
- Intrusion detection/prevention, firewall
入侵检测/防御，防火墙

Summary

- Key objectives of security: CIA
安全的核心目标：机密性、完整性与可用性
- What assets do we need to protect?
我们需要保护哪些资产？

- **Hardware, software, data, and communication facilities and networks**

硬件、软件、数据以及通信设施与网络

- How are those assets threatened?

这些资产面临何种威胁？

- Threat to assets

对于资产的威胁

- Threat consequences and attacks

威胁后果与攻击行为

- What can we do to counter those threats?

我们应采取何种措施来应对这些威胁？

- Security design principles

安全设计原则

- Security strategy

安全策略

- Tools

安全工具